

OpenBox v0.2.0

Plataforma de borda com privacidade auditável, hardening e monitoramento integrado

WireGuard

nftables

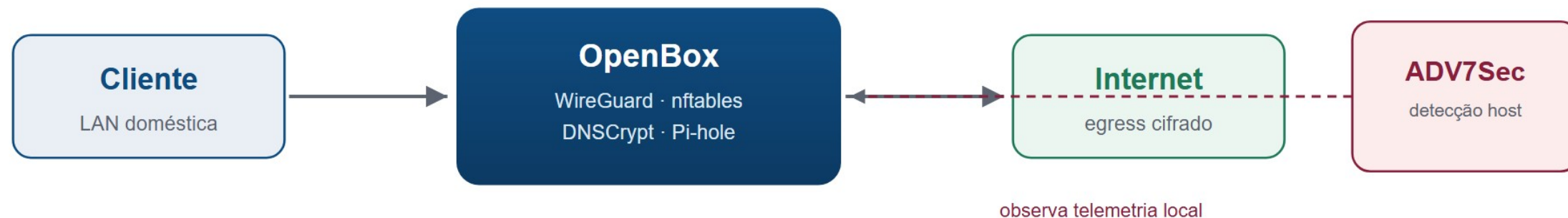
DNSCrypt

Pi-hole

Unbound

Tor

ADV7Sec





AGENDA

O que vamos percorrer

01

Problema e contexto

02

Estudo de caso: TV box

03

Linha do tempo

04

Arquitetura de borda

05

Fluxo de tráfego

06

Modelo de ameaça e risco

07

Plano de hardening

08

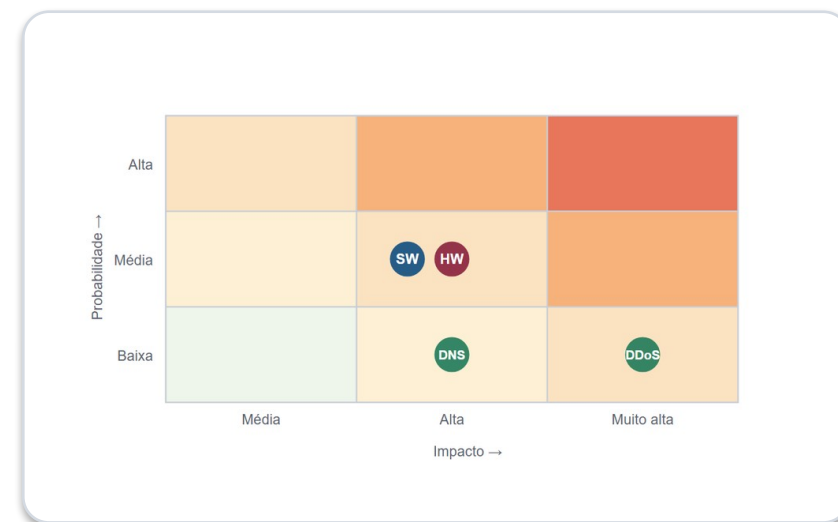
ADV7Sec — detecção

09

Runbook e evidências

10

Conclusão e carreira



Da ameaça de fábrica à borda auditável

+ **Anexo técnico** teardown de hardware (R3290_V8.1) e fase de flash/SSH

01

PROBLEMA

Dois vetores de risco no lar técnico

TV boxes genéricas saem de fábrica com firmware potencialmente comprometido; a workstation de desenvolvimento opera sem trilha forense. São problemas independentes.

B

Borda (rede doméstica)

DNS em texto claro pelo ISP; VPN sem kill switch — qualquer queda reintroduz o perfil bruto de tráfego.

E

Endpoint (workstation)

Sem baseline de integridade e sem alerta comportamental; o primeiro sinal de comprometimento costuma ser tardio.

10M+

dispositivos infectados — BadBox 2.0

1.3M

caixas Vo1d — Brasil é o nº 1

200–400

R\$/mês em assinaturas substituíveis



Tese. Segurança tratada de forma sistêmica — hardware, SO, rede, monitoramento, integridade e resposta — não como “antivírus”.

MXQ Pro 5G 4K — a ameaça de fábrica

Elemento	Observação
SoC	Rockchip RK3229 (placa R29_5G_LP3)
Memória	1 GB LPDDR3 — tuning conservador
Ethernet	100 Mbps — coerente com o custo
Firmware	comprometido de fábrica em lotes
Risco	backdoor, OTA, ADB aberto

Cadeia de suprimento

- ▶ BadBox 2.0 / Vo1d infectam o firmware antes da 1ª conexão
- ▶ Mitigação: wipe via maskrom + flash Armbian auditável
- ▶ Verificação pós-flash antes de qualquer tráfego de rede

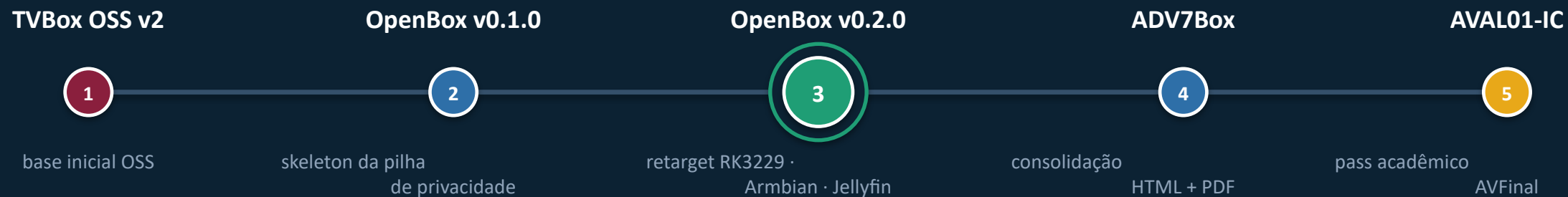
antes do 1º boot

o problema existe na cadeia, não na rede



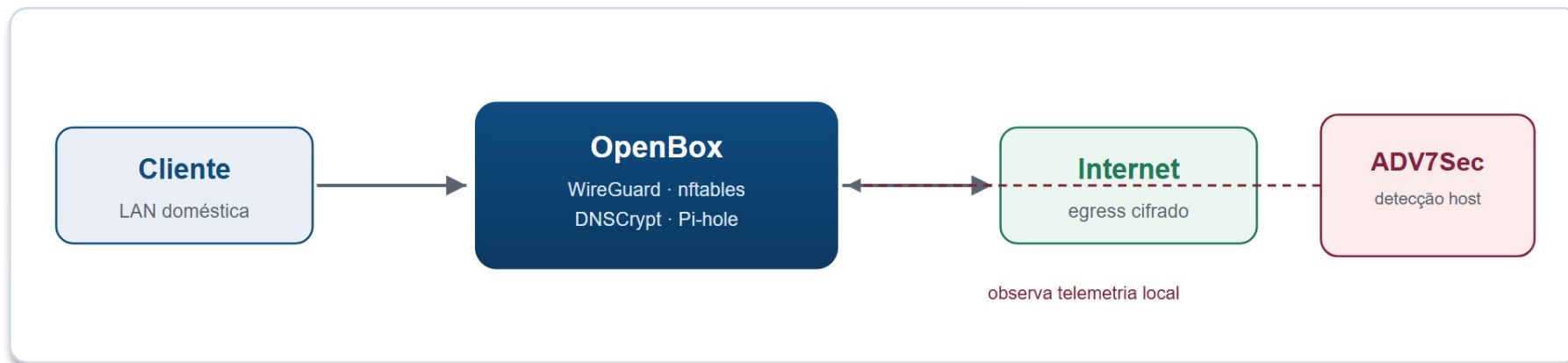
Valor acadêmico. O dispositivo conecta computação básica (ARM, bootchain, eMMC) a segurança real (firmware pré-infectado).

Linha do tempo do projeto



● **Da prova de conceito à entrega.** A troca de RPi 4 por RK3229 provou que hardware reaproveitado de baixo custo sustenta uma pilha de segurança honesta.

Defesa em profundidade, dois pilares



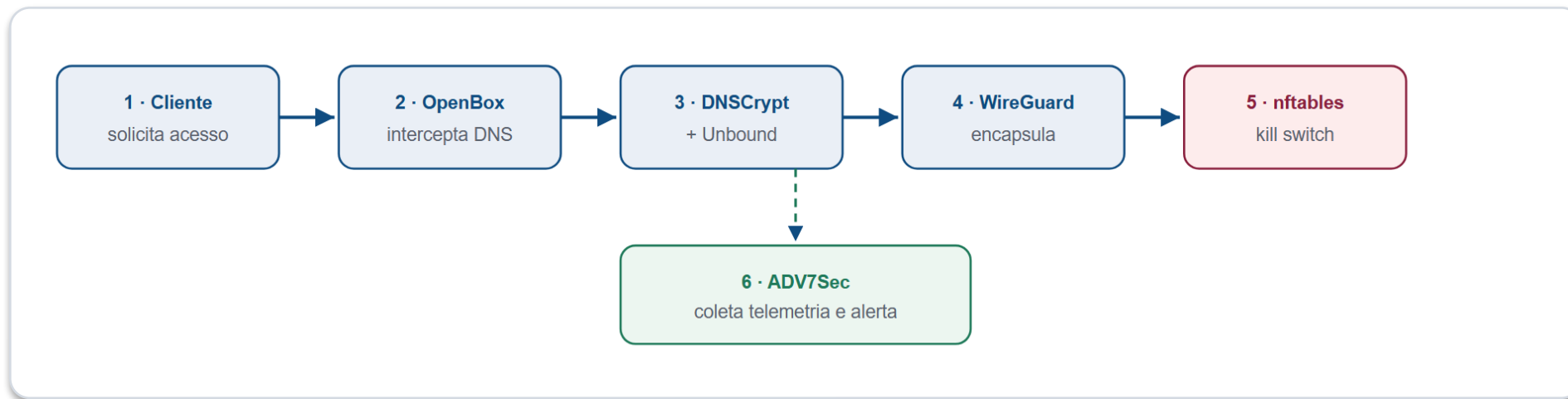
OpenBox — a borda

- ▶ WireGuard como única via de saída permitida
- ▶ nftables: política + kill switch atômico (fwmark 51820)
- ▶ DNS local e cifrado: dnscrypt-proxy + Unbound + Pi-hole

ADV7Sec — o host

- ▶ auditd, Falco, Suricata e Zeek agregados localmente
- ▶ Plano de detecção — observa, nunca bloqueia (preview-first)
- ▶ Logs em journald, sem SIEM e sem sink externo

Do cliente à Internet, sem vazar

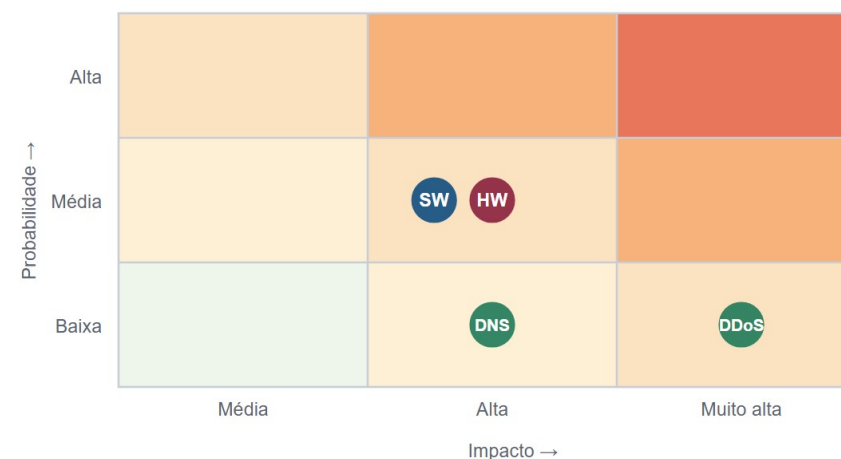


- | | | | | | |
|---|-------------------------------|---|---------------------------------|---|-----------------------------------|
| 1 | Cliente solicita acesso | 2 | OpenBox intercepta o DNS | 3 | dnscrypt-proxy + Unbound resolvem |
| 4 | WireGuard encapsula o tráfego | 5 | nftables bloqueia se a VPN cair | 6 | ADV7Sec coleta e alerta |

● **Critério.** Se a rede cai, nada sai. O kill switch é atômico e mantém allowlist apenas para o endpoint da VPN.

Modelo de ameaça e matriz de risco

Falha	Categoria	Nota
Queima do gateway / energia	Hardware	Alto
Erro de config. do firewall	Software	Alto
DDoS / interceptação	Rede	Alto
Vazamento de DNS	Rede	Médio/Alto



3 categorias, mitigação específica. Hardware, software e rede mantidas distintas para priorizar controles — não respostas genéricas. Adversário estatal e acesso físico ficam fora do escopo.

Plano de hardening

H

Hardware

UPS, backup de configuração, imagem de recuperação e equipamento reserva.

S

Software

Git e rollback, validação de configuração e testes automatizados antes e depois.

R

Rede

Firewall, VLAN, VPN obrigatória, DNS criptografado e rate limiting.

I

Integridade

AIDE e RKHunter, logs e alertas por ntfy sobre arquivos críticos.



Sem composições frágeis. Não se mistura UFW com nftables, nem se assume que o Tor sustenta streaming — Tor só para metadados.

ADV7Sec — telemetria host-side

Sensor	O que observa	Saída
auditd	syscalls e arquivos sensíveis	log estruturado
Falco	processos e rede	alerta + JSON
Suricata	assinaturas de rede	EVE JSON
Zeek	sessões e metadados	conn.log
AIDE	integridade de arquivos	baseline / diff

Preview-first

- ▶ Mostra o que faria antes de agir
- ▶ Detecção, não bloqueio ativo
- ▶ Favorece estudo e depuração

● **Útil quando a ameaça passou da borda.** Visão coerente de comportamento anômalo no endpoint, com normalização e alertas locais.

Runbook, validação e evidências

Healthchecks

```
$ systemctl status wg-quick@wg0 ...  
$ curl -4 https://ifconfig.io  
$ openbox-dnsleak-check.sh  
$ lynis audit system --quick
```

Artefatos versionados

- ▶ README.md — visão geral e diferenças do TVBox OSS
- ▶ CHANGELOG.md — histórico v0.1.0 → v0.2.0
- ▶ THREAT_MODEL.md — adversários e fronteiras
- ▶ RK3229_THREAT_RESEARCH.md — cadeia de suprimento
- ▶ RUNBOOK.md — operação e troubleshooting
- ▶ OBSIDIAN_VAULT.md — trilha de execução

14 págs · 3 formatos · 5 figuras

documentação reprodutível e auditável

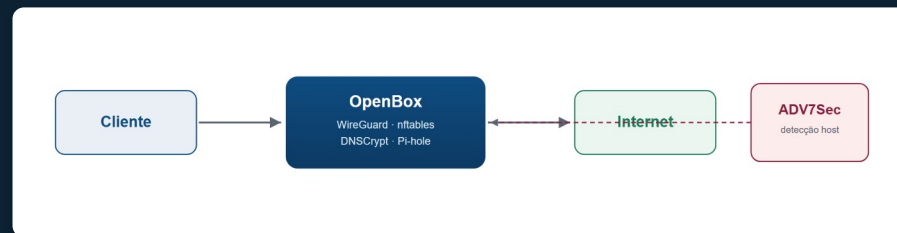
Borda mais segura, auditável e replicável

Direcionamento de carreira

Forte viés **Blue Team**: hardening, observabilidade, resposta a incidentes e documentação técnica.

Compatível com SOC, administração de redes, segurança de sistemas e engenharia de plataformas.

Evolui para automação maior, análise de alertas e inteligência local em semestres futuros.

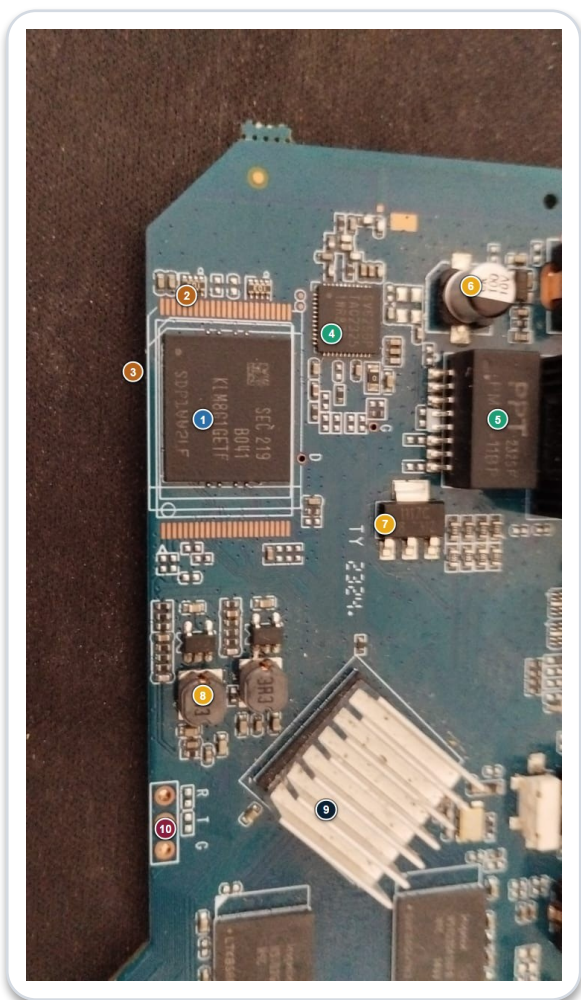


< R\$ 1.000

custo de entrada do laboratório

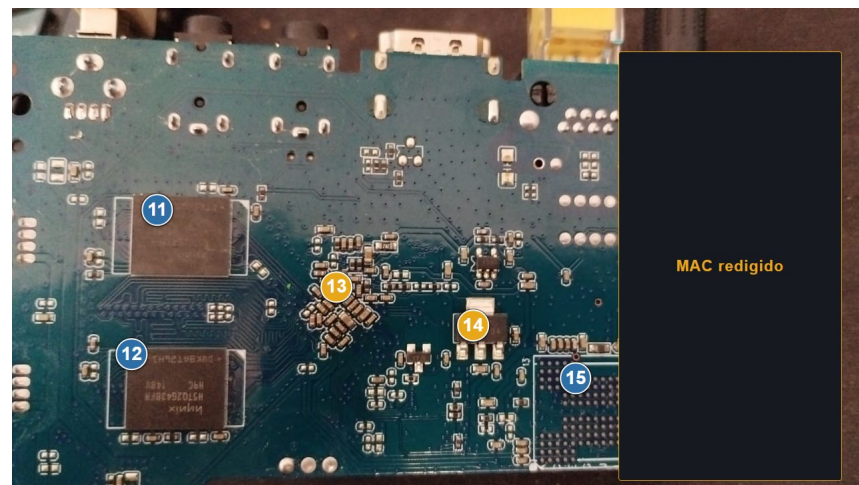
- **Em termos acadêmicos e práticos.** Estuda um cenário real, justifica a tecnologia e demonstra defesa — entregando uma borda residencial compreensível e verificável.

Estruturas da placa — face superior



- 1 eMMC Samsung KLM8G1GETF — 8 GB (armazenamento)
- 2 R-série — resistores no barramento eMMC (tap)
- 3 Trilha CLK (breakout) — short p/ maskrom
- 4 QFN-44 SVS6Z56F / TAC2121 — PHY/interface (provável)
- 5 PPT PM44-11BP — driver/MOSFET de potência (provável)
- 6 Capacitor eletrolítico CK 100 μ F — filtro de entrada
- 7 LDO AMS1117 (1117C) — regulador 3,3 V
- 8 Buck 3R3 (3,3 μ H) $\times$ 2 — trilhos de núcleo/DDR
- 9 SoC Rockchip RK3229 — sob o dissipador (família rk322x)
- 10 Header serial R / T / G — console UART de depuração

Memória, face inferior e portas



11–12 DRAM Hynix H5TQ2G43BFR (DDR3) — 4 chips $\approx$ 1 GB

13 Rede de resistores — terminação/strap do DDR

14 LDO 1117 (face inferior) — regulador auxiliar

15 Footprint BGA vazio — posição NAND/eMMC alternativa

16 Cristal/oscilador — referência de clock

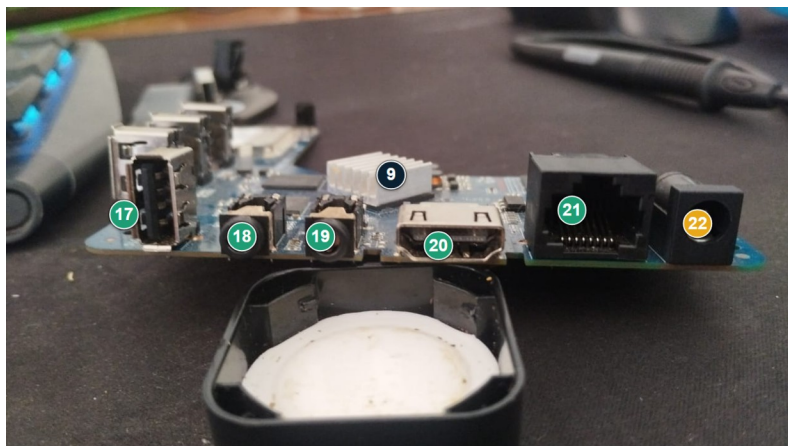
17 USB-A — porta host USB 2.0

18–19 AV 3,5 mm — saídas CVBS/áudio

20 HDMI — saída de vídeo digital

21 RJ45 — Ethernet 10/100

22 DC jack — entrada de alimentação 5 V



● **Privacidade & flash.** MAC redigido na face inferior; o micro-USB OTG é a porta usada para o flash via maskrom.

Fase de flash e SSH (rk322x)

Fase de flash – Windows (usbipd-win) + WSL Kali (rkdeveloptool)

```
# 1) Windows / PowerShell (admin): anexa o dispositivo USB ao WSL
PS> usbipd attach --wsl --busid 1-4
usbipd: info: usando a distro WSL 'kali-linux' para anexar o dispositivo...

# 2) WSL Kali (root): confirma o modo maskrom da Rockchip (PID 320b)
root@kali ~# lsusb | grep 2207
Bus 001 Device 012: ID 2207:320b Fuzhou Rockchip Electronics (RK3229 maskrom)
root@kali ~# rkdeveloptool id
DevNo=1 Vid=0x2207,Pid=0x320b,LocationID=104 Maskrom

# 3) grava Armbian rk322x-box (Debian Bookworm, armhf) na eMMC
root@kali ~# rkdeveloptool wl 0 Armbian_25.x_rk322x-box_bookworm.img
Write LBA from file (100%)
root@kali ~# rkdeveloptool rd
Reset Device OK.
```

Fase SSH – primeiro acesso ao Armbian + gate Phase 0

```
# host de desenvolvimento: primeiro acesso por SSH (autenticacao por chave)
ssh root@192.168.0.103
Welcome to Armbian 25.x (bookworm) – rk322x-box

# Phase 0 – gate de fingerprint (4 criterios obrigatorios)
root@openbox ~# cat /proc/device-tree/model
Rockchip RK3229 Box (familia rk322x)
root@openbox ~# dpkg --print-architecture
armhf
root@openbox ~# lsmod | grep -c wireguard
1
root@openbox ~# ls /dev/watchdog*
/dev/watchdog /dev/watchdog0

root@openbox ~# bash tools/fingerprint-rk3229.sh --gate
[ok] SoC = rockchip,rk3229
[ok] arch = armhf
[ok] modulo wireguard presente
[ok] /dev/watchdog* presente
Phase 0: PASS (4/4)
```

● **Reconstrução do procedimento documentado.** Valores reais do projeto — placa R3290_V8.1 · Armbian rk322x-box · host 192.168.0.103 · Phase 0 PASS (4/4). Sequência: maskrom → rkdeveloptool → boot → SSH por chave.